

The Oversight Threshold

Governing AI systems that a person can no longer independently verify

Mubien Ahsan · mubienahsan.com/research/autonomy-governance

Sources last checked 20 September 2026

ABSTRACT

Human oversight is the control that most AI governance frameworks lean on hardest. It is named in binding regulation, written into supervisory guidance, and recorded in risk registers as the reason an AI system is considered controlled. This paper argues that the control is load-bearing in exactly the situations where it is weakest, and that the failure is structural rather than a matter of effort.

The argument is this. As an AI system's autonomy and capability rise, the ability of a responsible person to independently verify what it decided falls. The governance intensity the system requires rises at the same time. The two cross. Past that crossing — the oversight threshold — a human approval step still produces a signature and stops producing a check, and nothing visible in the workflow changes when it happens.

The paper sets out a five-level autonomy scale mapped against eight governance dimensions, a five-part test for whether human oversight is doing real work, and an account of why verification capacity falls that distinguishes the fixable causes from the one that is not. That account turns on two problems the field has not solved: comprehension, because these systems are grown rather than written and nobody can say where a behaviour lives inside them; and alignment, because no objective can be specified precisely enough to guarantee that a capable system pursues what was intended rather than a proxy for it. The paper then argues that above the threshold, governance has to stop resourcing review and start constraining what a system is permitted to become and to reach.

The scope is deliberate. Whether these systems end somewhere catastrophic is a machine learning question, argued elsewhere by people better placed to argue it, and this paper does not try to settle it. It works one layer down, on the distance between what these systems can already do and what existing controls can actually establish — a question that is answerable now, about systems already running.

This is an argument and a framework. It is not an empirical study: no survey, incident dataset or client engagement sits behind it, and section 11 states what that limits. It is written in a personal capacity and is not legal, regulatory or professional advice.

CONTENTS

1. The question
2. The thesis
3. Why verification capacity falls
4. The AI Autonomy Governance Matrix
5. The Meaningful Human Oversight Test
6. The threshold, and how it gets crossed
7. What the current landscape assumes
8. What this means, by role
9. What organisations can do now
10. What is not solved
11. Limitations
12. Sources and method

1. The question

Somewhere in your organisation, a person clicked approve today. The record will show their name, the time, and that the item was reviewed. What it will not show is whether they could have said no — whether they had the information to disagree, the minutes to check, or the standing to be listened to if they had. Those are separate questions, and only the first one leaves a trace.

This paper is about the distance between them, and about what happens to that distance as AI systems become more capable.

One term is worth settling before going further, because almost everything here turns on it. Human oversight is the control that most AI governance frameworks lean on hardest: the requirement that a person sits between the system and the consequence, able to look at what it proposes and stop it. It appears in binding regulation, in supervisory guidance, and in a great many risk registers as the reason an AI system is considered under control. Put plainly, it is the promise that somebody is watching and can intervene.

So the question this paper asks is: at what point does that person stop being able to check what the system decided? Not through carelessness, but because the system has become too fast, too complex or too autonomous for checking to be possible in the time available.

That is usually treated as a question about the future, to be revisited when systems are more advanced than they are now. It is not. It is answerable today, about systems already in production, and the answer is frequently uncomfortable.

An agent that takes forty actions in nine seconds has not been reviewed by the person who clicked approve, whatever the workflow diagram says, and the record will show an approval either way. A reviewer facing two hundred model outputs in a working day is not exercising judgement on the two hundredth in the way they did on the first, and no report distinguishes the two. Neither situation requires a more capable model than the ones available now.

What makes this a governance problem rather than an operational one is that the failure is invisible to every instrument we currently point at it. The approval field is still there. The completion metric still reads one hundred per cent. The control description in the risk register still says human review. The only thing that has changed is whether that sentence is true, and there is no column for that.

Why this matters more than it did

Two things have changed recently enough that governance practice has not caught up with either.

The first is that systems act rather than advise. A model that produces a recommendation leaves the consequential step with a person. A system that can call tools, move money, modify records and instruct

other systems does not. The governance question stops being whether the output is accurate and becomes what the system is permitted to do, enforced by something other than the system's own judgement.

The second is that the systems themselves stopped being inspectable — you can no longer open one up and read what it will do. Section 3 explains how that happened, and it is the reason the problem does not yield to the usual remedies.

2. The thesis

As AI autonomy and capability rise, the ability of a person to independently verify the system falls — so governance has to intensify before the two cross, not after.

The argument fits in two sentences. The more capable and autonomous an AI system becomes, the harder it gets for a person to check its work — and at the same time, the more governance that system needs in order to be run responsibly. One of those is falling while the other is rising, so somewhere they cross.

That crossing point is what this paper calls the oversight threshold. It is not a capability level, a model size or a date on a calendar. It is the point at which a reviewer, working from what is actually in front of them, can no longer reach a conclusion of their own — only agree with the system's. Before that point, review is a check. After it, review is a signature.

The practical consequence is a matter of sequence. Governance that arrives after the crossing is documentation. Governance that arrives before it is control. Most programmes are structured to respond to incidents and therefore arrive after, which is why the framework in this paper is organised around what has to be true before a system moves up a level rather than what should happen when one goes wrong.

What this thesis does not claim

It takes no position on whether advanced AI ends somewhere catastrophic, on what timescale, or on whether the correct response is to slow down. Those are real questions and they are argued elsewhere by people better placed to argue them. Nor does it claim that human oversight is worthless — below the threshold it is often the strongest control available, and most of the practical recommendations in section 9 are about making it work.

It claims something narrower and, I think, harder to dispute: that human oversight works only under conditions that can be named and tested, and that a governance model which does not check them is asserting a control rather than holding one.

3. Why verification capacity falls

Section 2 said that a person's ability to check the system falls away as it becomes more capable. This section is about why it falls, and the why matters more than it may appear: it decides whether the problem is one an organisation can fix by trying harder.

Three fixable causes

There are three ordinary reasons a reviewer stops genuinely reviewing, and all three are fixable by an organisation that decides to fix them.

- Time. The reviewer has seconds where the decision needs minutes. Fixable by changing the volume, the staffing or the threshold at which review is triggered.
- Information. The reviewer sees the conclusion but not the inputs, the alternatives considered, or the confidence attached. Fixable by changing what the system surfaces.
- Standing. The reviewer can technically refuse and is treated as an obstruction when they do. Fixable, though rarely by the governance function alone, because it is a question about incentives rather than process.

These three account for most oversight failures in practice today, and a governance programme that addresses only these will still be substantially better than one that does not. They should not be skipped over on the way to the more interesting problem.

The cause that is not fixable that way

There is a fourth cause, and no amount of resourcing touches it. It is worth spelling out, because everything later in this paper rests on it.

Older software was written. Somebody decided what the program should do, expressed that decision as rules, and those rules are still sitting there in the code. You can read them. When the program misbehaves, you can find the line responsible and change it, and you can say with confidence what it will do next time.

Modern AI systems are not made that way. They are trained: shown enormous quantities of data, with the behaviour emerging from that exposure rather than from any rule a person wrote. Nobody authored the instruction that produces a given answer, and nobody can point to the place inside the model where that behaviour lives. This is the sense in which these systems are grown rather than written — the phrase is not a metaphor for complexity, it is a description of how they are made.

Interpretability research — the work of reading structure out of a model's internals rather than inferring it from behaviour — is making genuine progress on the general question of what those structures are. It

is not, today, a deployed method for explaining a specific decision to a reviewer, an auditor or a regulator. The gap between those two things is where a great deal of governance language currently sits without acknowledging it.

So verification capacity does not fall because reviewers become lazy or overloaded. Give one of them unlimited time, complete logs and total independence, and they still cannot say why it did what it did. It falls because the thing being checked stops being the kind of thing a person can check.

The strongest published version of this

The most forceful statement of the problem is Eliezer Yudkowsky and Nate Soares, *If Anyone Builds It, Everyone Dies: Why Superhuman AI Would Kill Us All*, published in September 2025. Soares is president of the Machine Intelligence Research Institute.

Their phrase for the mechanism above is that AI systems are grown, not crafted. Soares has put the regulatory case in those terms: that a superintelligent system would not be understandable, would not be predictable, and would not have human interests at heart.

From there they argue that a system built with anything close to current techniques, and substantially more capable than the people who built it, would not be controllable, and that the default outcome is severe enough to threaten human survival. Self-improvement compounds the problem: a system that can improve its own capability changes the thing being verified faster than a verification cycle can complete.

The alignment problem

Opacity is about whether you can see what the system is doing. There is a second and separate difficulty about whether what it is doing is what you asked for, and the field calls it the alignment problem. The two are routinely merged into one vague worry, which makes both easier to wave away.

The trouble is specification. You cannot write down everything you mean, so any objective handed to a capable optimiser is a proxy for the intent behind it — not through malice, but because it was only ever an approximation. The literature names three ways the proxy comes apart from the intent. Specification gaming, where a system satisfies the stated objective by a route nobody intended. Reward hacking, where it optimises the measure rather than the thing the measure stood for. Goal misgeneralisation, where behaviour that held up under evaluation turns out, once deployed, to have been pursuing something else. None has a general solution, and capability makes each worse rather than better, because a weak system pursuing the wrong goal simply fails at it.

The two problems compound, and that is the part worth holding on to. A specification failure inside a system you cannot inspect is not one you find by looking for it. You find it when the system acts. That is the whole case for constraining what a system may reach rather than trusting that somebody will notice in time.

Why the argument follows

I can follow this argument, and I think anyone working in governance should be able to. It is not a mystical claim about machines waking up. It is the two problems above — we cannot see inside, and we cannot say exactly what we meant — plus a third that compounds both: a system able to improve its own capability changes faster than any verification cycle can complete.

Each of the three is unremarkable on its own, and each is the ordinary understanding of how the technology works rather than a contested reading of it. Placed in sequence they describe something that becomes harder to check exactly as it becomes more consequential. The shape of the argument is sound.

The self-improvement step deserves particular attention from governance practitioners, because it is the one our methods are least prepared for. Every assurance technique available — testing, validation, independent review, certification — assumes the object holds still long enough to be assessed. A system that meaningfully improves its own capability breaks that assumption, and nothing in existing model risk practice is built for it.

Where I put my work

Where the argument ends — whether this leads somewhere catastrophic, and on what timescale — is a question about how capability scales and how systems behave at levels nobody has built. I am not a machine learning researcher, and I am not going to pretend I can settle that from a governance background. Readers who want that question argued should go to the people arguing it, including the book above and the reviewers who have contested parts of it.

The question also does not need to be settled for the problem in this paper to be real. It does not wait for superintelligence: it is already visible at level 4, in systems nobody claims are superhuman, and the response is the same whichever way the larger argument resolves. So this paper works one layer down, on the distance between what these systems can already do and what our existing controls can actually establish. Whether the endpoint is the one Soares describes is not mine to adjudicate. Whether human review is doing real work in a system running right now is mine — and unlike the first question, it is answerable this quarter.

4. The AI Autonomy Governance Matrix

The matrix exists to make the thesis testable. If governance intensity has to rise before verification capacity falls below it, then somebody has to be able to say where a given system sits and what that position requires. Five levels, eight dimensions.

A system is placed by what it can do, not by what the documentation says it is for. The distinction is the whole point: most systems that are governed as though they were one level down are governed that way because the paperwork was written before the permissions were widened.

The five levels

Level 1, assistive. The system produces information, analysis, a recommendation or a draft. It does not act on the world, and nothing it writes takes effect until a person does something with it. Everything consequential remains with the person.

Level 2, delegated task execution. The system carries out a clearly bounded task — a defined input, a defined output, narrow limits. It can touch systems, but the consequential step waits for approval.

Level 3, conditional autonomy. The system plans an approach, chooses tools, and takes a sequence of actions without approval for each one, as long as it stays inside defined limits. This is where most agent deployments now sit, and where the threshold is most often crossed without anyone noticing, because speed and volume do the crossing rather than capability.

Level 4, high autonomy. The system works towards a longer-running objective, adapts its strategy as it goes, and may coordinate several systems or other agents with limited intervention. A person may approve the objective; nobody can realistically inspect every intermediate decision. This is the highest level at which the governance methods described in this paper have been demonstrated to work at all, and it is already a stretch.

Level 5 is a scenario, and is treated as one throughout. In it, the system outperforms people across many relevant tasks, can accelerate parts of AI research, or can improve important aspects of its own operation, and review may no longer constitute verification because the reviewer cannot reproduce, understand or challenge the reasoning. Including it is not a prediction that such a system exists, is imminent or is inevitable. It is included because a framework that only describes what already exists cannot tell you whether it would survive contact with what comes next — which is the only question worth asking of a governance model in a field that moves at this speed.

The eight dimensions

Each level is mapped across eight dimensions, chosen to borrow the shape of existing risk practice rather than to invent a vocabulary that nobody else uses.

- Purpose and permitted use — what is this system for, and what is it explicitly not for?
- Authority and permissions — what may it actually reach and do, enforced outside the model?
- Human oversight — who reviews what, with what information, and can they say no?
- Testing and evaluation — what was tested, against what expected behaviour, and by whom?
- Monitoring and evidence — what is watched in production, and what would the record show?
- Intervention and containment — how is it stopped, how fast, and has that been exercised?
- Accountability and escalation — who owns the outcome, and where does a serious problem go?
- Independent assurance — who checks this who did not build it and does not report to whoever did?

Two of these deserve particular attention because they are where governance most often substitutes a description for a control.

Authority and permissions is a question about enforcement, not instruction. A limit expressed in a system prompt is a request. A limit expressed in the credentials the system holds is a constraint. The difference only becomes visible when the system is under adversarial pressure, at which point it is too late to discover which one you had.

Intervention and containment turns on whether the mechanism has been exercised. A documented shutdown procedure that has never been run has an unknown duration and unknown gaps, and both of those are discovered during the incident. Stopping the interface is not stopping the system: credentials, tools, queued work and delegated agents each have to be reached.

What the matrix is not

The intensity weights are relative, for comparing levels against each other. They are not measurements, not a maturity model, and not a score that adds up to a rating. Anyone can read them as a scorecard, and it will make the framework worse, because the moment a number can be reported it starts being managed.

5. The Meaningful Human Oversight Test

Adding a human approval button does not create oversight. It creates a record that somebody was present. Whether that person was exercising judgement depends on five separable conditions, and a system can satisfy four of them and still fail, because the one it misses is the one that mattered.

- Understand. Can the responsible person understand the objective, the boundaries, the relevant inputs and the proposed action? Everything else depends on this one.
- Challenge. Can that person question the recommendation and reach a different conclusion, without simply deferring to it?
- Verify. Can they independently test the important facts, assumptions or outputs before harm occurs?
- Intervene. Can they interrupt or change the behaviour while the decision is still reversible?
- Stop. Can they reliably end the system's authority, access and ability to act across every connected tool?

Why these five and not others

They are ordered as a dependency chain. You cannot challenge what you do not understand, cannot verify what you cannot challenge, cannot sensibly intervene in what you have not verified, and stopping is the only one that still works when the others have failed — which is why it is the one most worth exercising and the one least often exercised.

Each fails in a way that is hard to see from inside. Understanding fails when the reviewer can describe what the system produced but not why, and fills the gap with an assumption about how it probably works. Challenge fails when overriding is possible in principle, never happens in practice, and nobody has asked why. Verification fails when the only evidence available to the reviewer is evidence the system produced, which makes agreement the only reachable outcome. Intervention fails when it is slower than the process it is meant to interrupt and nobody has measured the difference. Stopping fails when the procedure exists on paper and has never been run.

Verification is not review

The third condition carries more weight than the others, and is the one most often conflated with review. Review asks whether the output looks right. Verification checks it against something the system did not supply. A reviewer working only from the system's own evidence is performing review, and the result is structurally incapable of disagreeing.

This distinction is why volume alone can put an organisation past the threshold with no change in model capability. Once the quantity of decisions makes independent checking impossible, review is all that is

left, and review agrees.

Making the answer observable

The test above is a structured way to have an argument, and its answers are self-reported. There is a harder version available, and it is the single most useful thing in this paper for a practitioner: seed errors and see whether review catches them.

If seeded errors are caught no more often than they would be by a reviewer approving without looking, the organisation has measured that its primary control is documentation. That is an uncomfortable result and a genuinely evidential one, and it converts a question about culture into a number that can be tracked. It is also the only method described here that produces evidence rather than opinion, which is why it belongs in section 9 as well as here.

6. The threshold, and how it gets crossed

The threshold arrives from several directions and rarely announces itself. Four routes account for most crossings, and none of them requires a more capable model than what is already deployed.

- **Speed.** The system acts faster than review can happen, so approval moves to a sample, or to afterwards, while continuing to be described as approval.
- **Volume.** The reviewer faces two hundred decisions a day. Attention per decision collapses long before anyone reports a problem, because nothing in the process registers the difference between the first and the two hundredth.
- **Opacity.** The reasoning cannot be reconstructed, so review is of the output alone — and an output that looks reasonable is not evidence that the path to it was.
- **Dependence.** The only evidence available to the reviewer is evidence the system produced, which makes agreement the only conclusion reachable from the material on the desk.

Each can cross the line on its own. In practice they arrive together, because the same deployment decision that raises volume usually raises speed.

Why nothing visible changes

This is the part that makes the threshold a governance problem rather than an operational one. At the moment of crossing, every artefact a governance function inspects continues to read exactly as it did before. The approval field is populated. The completion metric is unchanged. The control description in the risk register still says human review, and the control has not been removed — it has stopped working, which is not the same thing and is not detected by the same instrument.

An organisation can therefore cross the threshold, remain fully compliant with its own documented framework, and pass an audit of that framework, while holding materially less control than the framework asserts. No deception is required for this. Everyone involved can be acting in good faith.

The change of question

The practical move follows directly. Stop asking whether a human reviews the output. Start asking whether the reviewer could have reached a different conclusion.

The first question has an answer that is always yes and means nothing. The second has an observable answer, costs something to obtain, and tells you whether you hold the control you have written down.

7. What the current landscape assumes

This section describes what published frameworks and regulation require, and where the assumption underneath them meets the threshold. Throughout, voluntary instruments are identified as voluntary and binding ones as binding, because collapsing the two is the most common error in this area — and the most flattering one, since it makes a governance programme sound more obligatory than it is.

Binding: the EU AI Act

Article 14 of the EU Artificial Intelligence Act requires that high-risk systems be designed and developed so that they can be effectively overseen by natural persons while in use. The word doing the work is effectively. The obligation attaches to whether oversight works, not to whether a reviewer is present — which is precisely the distinction this paper is built on, and it is already law rather than a proposal.

That is a stronger requirement than most implementations of it acknowledge. An organisation that can evidence a reviewer, an approval and a procedure has evidenced presence. Effectiveness is a claim about capability under operating conditions, and the five conditions in section 5 are one way of making it testable. I am not aware of a settled method for evidencing it, which is an open question rather than a criticism of the Act.

The Act also addresses general-purpose AI models — GPAI, the broad models adapted to many downstream tasks rather than built for one — where the model presents systemic risk. Providers must then evaluate, assess and mitigate that risk, report serious incidents and maintain cybersecurity. The Act sets a training-compute threshold of 10^{25} floating-point operations, or FLOP, as a presumption of systemic risk: a count of the raw arithmetic performed in training the model. A compute threshold is an administrable proxy rather than a measure of how autonomous a deployed system is, and the two can diverge in both directions: a modest model with broad permissions and fast tools can sit further past the oversight threshold than a large one that only drafts.

Supervisory guidance: OSFI E-23

Canada's Office of the Superintendent of Financial Institutions (OSFI), the prudential regulator for federally regulated banks and insurers, published the final version of Guideline E-23 on model risk management on 11 September 2025, in force 1 May 2027 for federally regulated financial institutions. It expands model risk management to cover AI and machine learning explicitly, with risk-proportionate expectations across the model lifecycle.

Model risk management — MRM, the discipline that governs how an institution develops, validates and monitors the models it relies on — is the closest existing practice to what autonomous systems need, and it is the right foundation. Its inherited assumption is worth naming: that the object being governed

holds still long enough to be validated, and that validation is a periodic exercise against a documented specification. A system that plans, adapts and acts continuously stresses both halves of that assumption, and a system that improves its own capability breaks them.

Voluntary: NIST and ISO/IEC 42001

The AI Risk Management Framework published by NIST, the US National Institute of Standards and Technology, together with its Generative AI Profile, is voluntary. Neither is a certification and neither is binding. The Govern, Map, Measure, Manage structure is the closest thing the field has to a common vocabulary, which is a real contribution and frequently overstated into an obligation it does not carry.

ISO/IEC 42001 — issued jointly by the International Organization for Standardization and the International Electrotechnical Commission — is a certifiable management-system standard for AI. It governs how an organisation manages AI. That is not the same as evidence that a particular system is safe at a given autonomy level, and a certificate should not be read as though it were. Management-system certification tells you that a process exists and is followed; the question in this paper is whether the control that process describes is operative.

Evaluative bodies and industry commitments

The United Kingdom's AI Security Institute was renamed from the AI Safety Institute in February 2025, with a stated shift towards security-relevant risks. In the United States, the Center for AI Standards and Innovation was renamed from the US AI Safety Institute in June 2025, with a stated focus on demonstrable risks and on standards. Both publish evaluations and research. Neither is a regulator and neither issues binding requirements, and both are sometimes cited in governance material as though they did.

Frontier safety frameworks, arising from voluntary commitments made at the 2024 Seoul summit, define capability thresholds and the safeguards required before crossing them. These are self-defined and self-assessed. They are also the closest thing in existing practice to governing levels 4 and 5 — which is worth noticing in both directions. The structure is right; the assurance underneath it is the weakest part, because the entity setting the threshold is the entity that benefits from crossing it.

The common gap

Across all of these, human oversight appears as a control and its operating conditions are not specified. What is required is that oversight exist and be effective. What is not provided is a method for establishing that it is, or a trigger for noticing when it has stopped being.

That gap is where this framework is aimed. It is a gap in method, not in intent, and it is not filled by adding another requirement that oversight be meaningful.

8. What this means, by role

The threshold lands differently depending on what you are accountable for. What follows is the question each role should be able to answer, rather than a list of responsibilities.

Boards and executive committees

The question is not how many AI systems the organisation runs. It is which of them can act without a person approving the specific action, and what the largest single thing any of them could do is. A board that knows the count but not the blast radius knows the less useful number.

The reporting change that follows: an assurance that all AI decisions are subject to human review should be met with a request for the evidence that review can reject. Absent that evidence, the assurance describes a workflow rather than a control.

Risk functions

Autonomy belongs in the risk taxonomy as its own axis, separate from criticality and from data sensitivity. A low-criticality system at level 3 can carry more risk than a high-criticality system at level 1, because the exposure comes from what it may do unsupervised rather than from what it processes.

The second change is to treat every permission grant as a risk decision with a date on it. Permissions accumulate quietly; nobody reassesses a system because a tool was added.

Internal audit

This is where the framework has the most direct application, because internal audit is the function whose job is to test whether a control operates rather than whether it exists.

Auditing human oversight by confirming that approvals were recorded tests the presence of the control. Auditing it by seeding known errors and measuring whether review catches them tests the control. The second is harder to arrange, occasionally unwelcome, and the only one of the two that produces evidence.

Compliance

The risk specific to this function is language. A voluntary framework described in a policy as a requirement, or an evaluative body cited as though it were a regulator, produces a document that overstates the obligation and therefore overstates the assurance. The correction is mechanical: label every source with what it is, every time.

Where the EU AI Act applies, Article 14's effectiveness standard should be read as what it says. A compliance position built on demonstrating that a reviewer exists is not obviously sufficient against a requirement about whether oversight can be exercised.

System owners

The owner is the person who should be able to answer, without preparation, what the system may reach, what it may do there, and what happens if it is wrong. If the answer requires consulting the team that built it, the ownership is nominal.

The most useful single discipline is to write down what the system is explicitly not for, and to enforce that outside the model.

Developers and engineering

Most of what this paper asks for is an engineering property rather than a policy one. Permissions that hold regardless of what the model decides. Actions reversible by construction where that is possible. A stop that reaches credentials, queued work and delegated agents rather than the interface. Logs that record objectives and permissions, not only outputs.

These are cheaper to build at design time than to retrofit after an incident, and they are the controls that continue to function above the threshold, when the ones that depend on a person do not.

9. What organisations can do now

Nothing in this list requires a research breakthrough, a vendor, or a change in the regulatory position. It requires deciding to.

- Keep an inventory of AI systems and agents that records what each may reach and do, not only what it is called and who owns it.
- Classify by autonomy, capability and potential impact as three separate axes, because a system can be high on one and low on the others.
- Define permitted objectives, tools, data, transactions and counterparties explicitly, and write down what is out of scope as carefully as what is in it.
- Enforce those limits outside the model, in credentials and permissions, rather than inside it in instructions.
- Set capability and deployment thresholds in advance, so the decision to widen autonomy is made deliberately rather than discovered afterwards.
- Require evidence before a system moves up a level, and specify what evidence would count before it is asked for.
- Test whether human reviewers can genuinely detect errors, by seeding them. This is the one that converts opinion into evidence.
- Measure the intervention window: how long between a system deciding and the action becoming irreversible, against how long a person takes to notice and act.
- Exercise the stop, end to end, including delegated agents and cached credentials, and record how long it actually took.
- Log objectives, permissions, actions, changes and interventions — enough that a reconstruction is possible without the system's cooperation.
- Monitor for unexpected capability changes and for attempts to work around restrictions, and treat both as incidents rather than curiosities.
- Separate who builds, who validates and who approves. Independence is a structural property, not an attitude.
- Use independent assurance for higher-autonomy systems, and accept that assurance by people who report to the builder is a weaker instrument than it looks.
- Reassess whenever the model, tools, permissions or operating context change. Each of those can move a system across the threshold without any decision being taken.

If only one of these is done, make it the seeded-error test. It is the only item that tells you whether the control you are relying on is real, and its result determines how much the other thirteen matter.

10. What is not solved

A framework that quietly implies the hard problems are handled is worse than no framework, because it converts an open risk into a closed item. These remain open, and controls that reduce their impact should not be described as solutions to them.

Prompt injection

Unsolved as an architectural matter. Mitigations reduce impact; none reliably prevents instructions embedded in fetched content from being followed. The defensible posture is to treat containment as the control rather than detection, and to design on the assumption that it will happen.

Interpretability

An active research field, not a deployed assurance method. Being able to inspect some internal structure is not the same as being able to explain a particular decision to a regulator, and the distance between those two is the subject of section 3.

Alignment and specification

A system pursuing a slightly wrong objective competently is a known failure mode with no general solution. Capability makes the consequences larger, not smaller, which is the one structural reason to treat capability increases as risk events in their own right.

Deceptive or strategically withheld behaviour

Studied, not resolved. Evaluations a system can anticipate are weaker evidence than evaluations it cannot, and distinguishing the two is itself unsolved. This directly undercuts the evidential value of pre-deployment testing at higher levels, and no current framework accounts for it.

Reliable shutdown

Straightforward in principle and routinely incomplete in practice — delegated agents, cached credentials, queued work, and self-contained tokens that remain valid until they expire. A self-contained token has no built-in kill switch; revoking access to it depends on the infrastructure around it, not on the token.

11. Limitations

What this paper is, and is not, stated plainly so that a reader can discount it appropriately.

- This is an argument and a framework, not an empirical study. No survey, incident dataset, benchmark or client engagement sits behind it. Where it claims something about how organisations behave, that is an argument from reasoning and observation, not a measurement, and should be weighed as such.
- The five levels are mine. They are a way of organising the argument, not a standard, and nobody is obliged to place a system where I would place it. Reversibility and blast radius may turn out to predict governance need better than autonomy does.
- The intensity weights are relative and illustrative. They are not measured, and treating them as a score would be a misuse.
- The threshold is argued, not located. I do not have a method for measuring where it sits for a given system, which is the largest open problem in the framework and the one I would most like to be wrong about.
- The regulatory summaries are my reading of primary material as at the date on this paper, in a field that moves quickly. They are summarised rather than quoted, and should be checked against current versions before being relied on.
- The framework is shaped by a financial-services and internal-audit perspective. It will fit sectors with established model risk practice more comfortably than sectors without it.
- Level 5 is a scenario used to stress-test the framework. Nothing in this paper should be read as a claim about whether, or when, such a system will exist.

Open questions

- Where the oversight threshold sits for a given system, and whether it can be measured rather than argued about.
- Whether effective oversight in regulation can be evidenced at all above level 3, or whether it quietly becomes a documentation requirement.
- What independent assurance means when the assured system is more capable than the assurer at the task being assured.
- How to evidence that intervention remains possible, rather than asserting it from a design document.
- Whether autonomy levels are the right axis at all.

12. Sources and method

Every source is summarised in my own words rather than quoted at length, and labelled with what kind of instrument it is. A voluntary framework and a binding regulation carry very different weight and are routinely cited as though they did not.

The five levels and the five-part oversight test are mine. The eight dimensions borrow their shape from existing risk practice rather than inventing a vocabulary. Where I make an argument it is identified as an argument; where I report what an instrument requires, that is separable from what I think about it.

Names and dates were checked rather than recalled: the UK body was renamed the AI Security Institute in February 2025; the US body became the Center for AI Standards and Innovation in June 2025; OSFI E-23 was finalised on 11 September 2025 and comes into force on 1 May 2027. Sources were last checked on the date shown on the cover of this paper. In this field that date matters, and a reader finding this later should treat the regulatory sections as a starting point rather than a current position.

One source is of a different kind from the others and is flagged as such. *If Anyone Builds It, Everyone Dies* is a book making an argument. It carries no authority beyond its reasoning, and it is included because it states the comprehension mechanism most clearly. Section 3 sets out why I find the reasoning followable, and is explicit that where that reasoning ends is a machine learning question rather than a governance one, and so not a question this paper attempts to settle.

Declarations

Written in a personal capacity. This is not the position of any employer, is not derived from any employer's methodology or client work, and describes no client, engagement or internal material. It is not legal, regulatory or professional advice, and it is not a certification, an audit opinion or a compliance conclusion. No compensation was received for writing it and no organisation reviewed it before publication.

AI tools were used in drafting and editing, as they are for most of what I publish. The argument, the framework and the judgements are mine, and the errors are too.

13. References

[1] **AI Risk Management Framework (AI RMF 1.0) and the Generative AI Profile** — NIST (US National Institute of Standards and Technology). **FRAMEWORK**

Voluntary. The Govern / Map / Measure / Manage structure is the closest thing to a common vocabulary; the Generative AI Profile adds risks specific to these systems. Not a certification and not binding.

<https://www.nist.gov/itl/ai-risk-management-framework>

[2] **ISO/IEC 42001 — AI management systems** — ISO/IEC (International Organization for Standardization / International Electrotechnical Commission). **STANDARD**

Certifiable management-system standard. It governs how an organisation manages AI, which is not the same as evidence that a particular system is safe at a given autonomy level.

<https://www.iso.org/standard/42001>

[3] **Guideline E-23 — Model Risk Management** — OSFI — Office of the Superintendent of Financial Institutions (Canada). **SUPERVISORY GUIDANCE**

Final version published 11 September 2025, in force 1 May 2027 for federally regulated financial institutions. Expands model risk management to cover AI and machine learning explicitly, with risk-proportionate lifecycle expectations.

<https://www.osfi-bsif.gc.ca/en/guidance/guidance-library/guideline-e-23-model-risk-management-2027>

[4] **Artificial Intelligence Act — Article 14, human oversight** — European Union. **REGULATION**

Binding. High-risk systems must be designed so that they can be effectively overseen by natural persons while in use. The obligation attaches to effectiveness, not to the presence of a reviewer — which is the distinction this whole framework turns on.

<https://artificialintelligenceact.eu/article/14/>

[5] **Artificial Intelligence Act — general-purpose AI with systemic risk** — European Union. **REGULATION**

Binding. Providers of general-purpose AI models — GPAI, the broad models that are adapted to many downstream tasks rather than built for one — must, where the model presents systemic risk, evaluate, assess and mitigate that risk, report serious incidents and maintain cybersecurity. The Act sets a training-compute threshold of 10^{25} FLOP, floating-point operations, as a presumption of systemic risk: a measure of the raw arithmetic used to train the model, which is administrable precisely because it can be counted, and which is a proxy for capability rather than a measure of it.

<https://artificialintelligenceact.eu/high-level-summary/>

[6] **AI Security Institute** — United Kingdom. **FRAMEWORK**

Renamed from the AI Safety Institute in February 2025, with a stated shift towards security-relevant risks. Publishes evaluations and research; it is not a regulator and issues no binding requirements.

<https://www.aisi.gov.uk/>

[7] **Center for AI Standards and Innovation (CAISI)** — NIST / US Department of Commerce.

FRAMEWORK

Renamed from the US AI Safety Institute in June 2025, with a stated focus on demonstrable risks and on standards. Evaluative and standards-setting rather than regulatory.

<https://www.nist.gov/caisi>

[8] **Frontier safety frameworks** — Frontier AI developers. **INDUSTRY COMMITMENT**

Voluntary commitments made at the 2024 Seoul summit, implemented as published frameworks that define capability thresholds and the safeguards required before crossing them. Self-defined, self-assessed, and the closest existing practice to levels 4 and 5 — which is worth noticing in both directions.

<https://www.gov.uk/government/publications/frontier-ai-safety-commitments-ai-seoul-summit-2024>

[9] **If Anyone Builds It, Everyone Dies: Why Superhuman AI Would Kill Us All** — Eliezer Yudkowsky and Nate Soares (MIRI), September 2025. **ARGUMENT**

A book, not a standard, and it carries no authority beyond its reasoning. Included because it states the strongest published version of the comprehension problem: that these systems are grown rather than designed, that nobody understands how their internals produce their behaviour, and that this is why a sufficiently capable system would not be controllable. The reasoning is followable and I follow it. Where it ends is a question about machine learning rather than about governance, and the section on the comprehension limit says which of the two I am writing from.

https://en.wikipedia.org/wiki/If_Anyone_Builds_It,_Everyone_Dies

© 2026 Mubien Ahsan. Free to use and share within your organisation with attribution. Version 1.0, 20 September 2026.